



REPORT

ผลวิเคราะห์ Credential Leak เดือนกุมภาพันธ์ ปี 2025



ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ (ศปช.)
สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ

Email: thaicert@ncsa.or.th

Website:

<https://www.ncsa.or.th>

<https://www.thaicert.or.th>

120 หมู่ 3 อาคารรัฐประศาสนภักดี (อาคารบี) ชั้น 7 ศูนย์ราชการเฉลิมพระเกียรติ 80 พรรษา
5 ธันวาคม 2560 ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพฯ 10210



คำนำ

รายงานผลการวิเคราะห์ Credential Leak เดือนกุมภาพันธ์ ปี 2025 นี้จัดทำขึ้นเพื่อให้ข้อมูลเชิงลึกเกี่ยวกับสถิติ Credential Leak ที่เกิดขึ้นในช่วงเดือนกุมภาพันธ์ โดยการวิเคราะห์เน้นแสดงประเภทของหน่วยงานที่ได้รับผลกระทบ ซึ่งประกอบด้วยหน่วยงานควบคุมหรือกำกับดูแล (Regulators) หน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ (CII) และหน่วยงานรัฐบาล (GOV) รวมถึงจำนวนเหตุการณ์ (Event) ที่เกิดขึ้นในเดือนดังกล่าว นอกจากนี้ รายงานยังได้นำเสนอแนวทางการป้องกันและรับมือที่สามารถนำไปใช้ได้จริง เพื่อเสริมสร้างความปลอดภัยทางข้อมูล ทั้งในระดับองค์กรและบุคคลทั่วไป พร้อมทั้งช่วยเตรียมความพร้อมในการลดความเสี่ยงจากภัยคุกคามทางไซเบอร์ที่พัฒนาและเปลี่ยนแปลงอย่างต่อเนื่อง

รายงานฉบับนี้มีเป้าหมายเพื่อช่วยให้ผู้อ่านเข้าใจภาพรวมของสถานการณ์ Credential Leak ได้ชัดเจนมากขึ้น และสามารถนำข้อมูลที่ได้ไปปรับใช้เพื่อ ยกระดับระบบป้องกันและสร้างความมั่นคงทางไซเบอร์ได้อย่างมีประสิทธิภาพมากขึ้นในอนาคต

สารบัญ

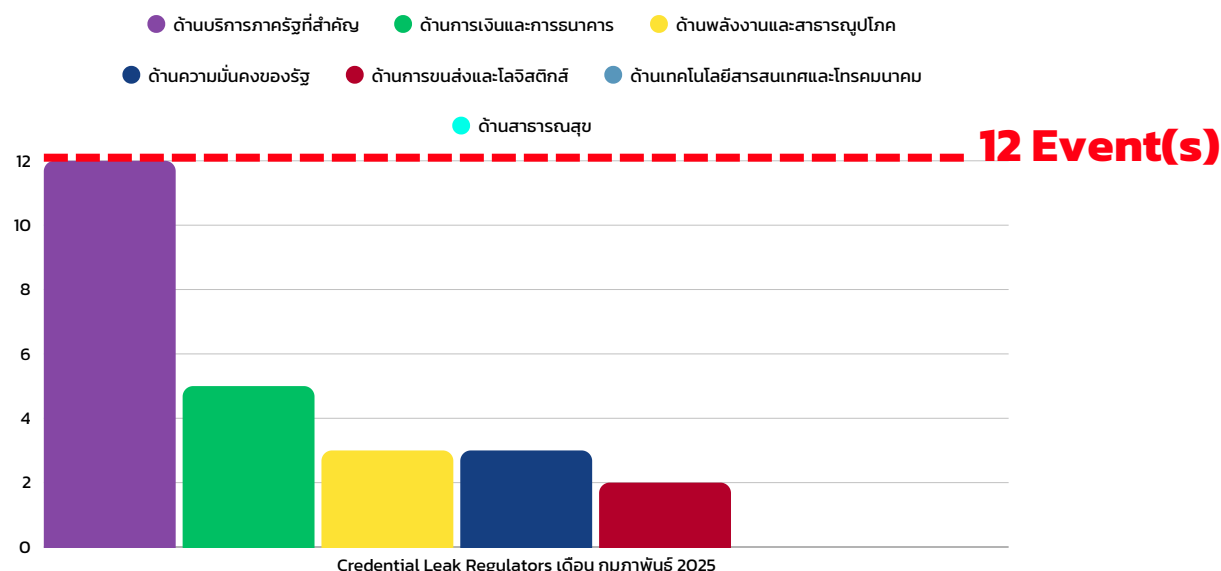
ภาพรวม Credential Leak เดือนกุมภาพันธ์ ปี 2025 ของหน่วยงานควบคุมหรือกำกับดูแล (Regulators).....	1
ภาพรวม Credential Leak ปี 2025 ของหน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ (CII).....	2
ภาพรวม Credential Leak ปี 2025 ของหน่วยงานรัฐบาล (GOV)	3
แนวทางการป้องกันและรับมือ.....	4



ภาพรวม Credential Leak เดือนกุมภาพันธ์ ปี 2025 ของหน่วยงานควบคุมหรือกำกับดูแล (Regulators)

ในเดือนกุมภาพันธ์ ปี 2025 ของหน่วยงานควบคุมหรือกำกับดูแล (Regulators) แสดงให้เห็นถึงความเสี่ยงที่ยังคงมีอยู่ โดยเฉพาะในหน่วยงานด้านบริการภาครัฐที่สำคัญพบ Credential Leak สูงสุดถึง 12 เหตุการณ์ รองลงมาด้านการเงินและการธนาคาร 5 เหตุการณ์ ด้านพลังงานและสาธารณูปโภค 3 เหตุการณ์ ด้านความมั่นคงของรัฐ 3 เหตุการณ์ ด้านการขนส่งและโลจิสติกส์ 2 เหตุการณ์ และมีหน่วยงาน 2 ด้าน ที่ไม่พบ Credential Leak ได้แก่ ด้านเทคโนโลยีสารสนเทศและโทรคมนาคม และด้านสาธารณสุข

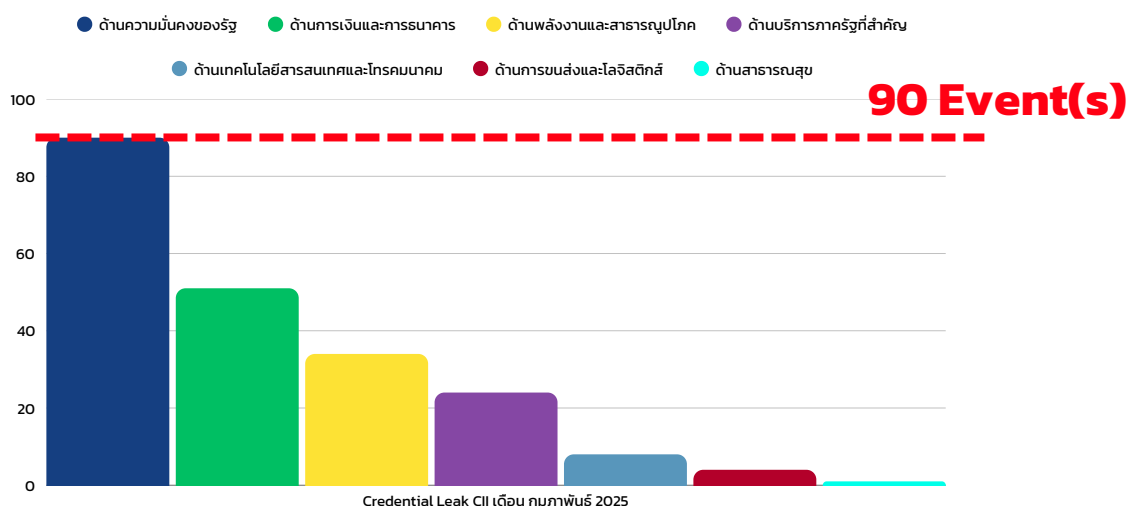
ประเภทหน่วยงาน	Event(s)
ด้านบริการภาครัฐที่สำคัญ	12
ด้านการเงินและการธนาคาร	5
ด้านพลังงานและสาธารณูปโภค	3
ด้านความมั่นคงของรัฐ	3
ด้านการขนส่งและโลจิสติกส์	2
ด้านเทคโนโลยีสารสนเทศและโทรคมนาคม	0
ด้านสาธารณสุข	0



ภาพรวม Credential Leak เดือนกุมภาพันธ์ ปี 2025 ของหน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ (CII)

ในเดือนกุมภาพันธ์ ปี 2025 ของหน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ (CII) แสดงให้เห็นถึงความเสี่ยงที่สำคัญ โดยเฉพาะในหน่วยงานด้านความมั่นคงของรัฐที่พบ Credential Leak สูงสุดถึง 90 เหตุการณ์ รองลงมาด้านการเงินและการธนาคาร 51 เหตุการณ์ ด้านพลังงานและสาธารณูปโภค 34 เหตุการณ์ ด้านบริการภาครัฐที่สำคัญ 24 เหตุการณ์ ด้านเทคโนโลยีสารสนเทศและโทรคมนาคม 8 เหตุการณ์ ด้านการขนส่งและโลจิสติกส์ 4 เหตุการณ์ ด้านสาธารณสุข 1 เหตุการณ์

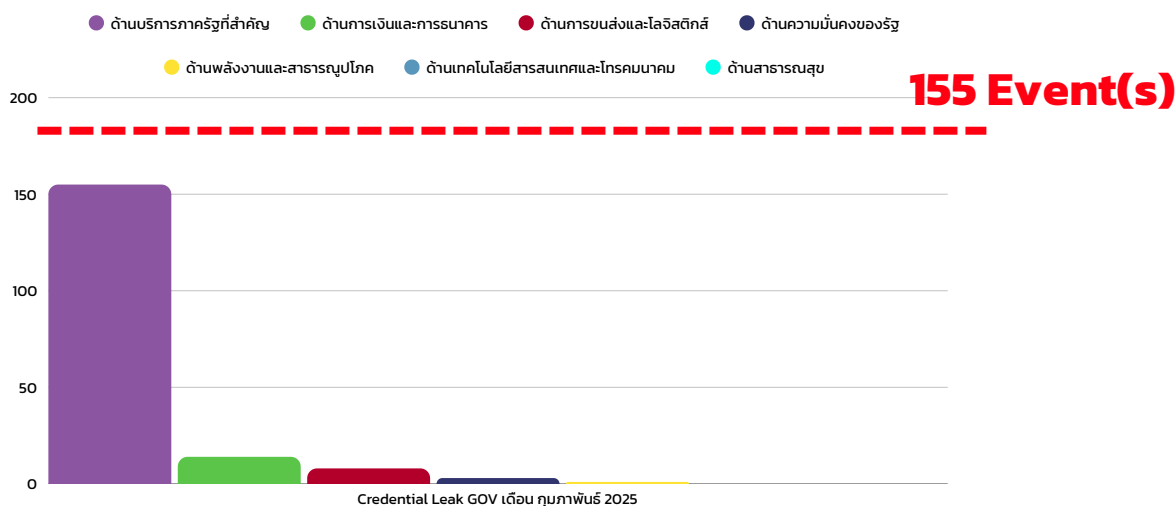
ประเภทหน่วยงาน	Event(s)
ด้านความมั่นคงของรัฐ	90
ด้านการเงินและการธนาคาร	51
ด้านพลังงานและสาธารณูปโภค	34
ด้านบริการภาครัฐที่สำคัญ	24
ด้านเทคโนโลยีสารสนเทศและโทรคมนาคม	8
ด้านการขนส่งและโลจิสติกส์	4
ด้านสาธารณสุข	1



ภาพรวม Credential Leak เดือนกุมภาพันธ์ ปี 2025 ของหน่วยงานรัฐบาล (GOV)

ในเดือนกุมภาพันธ์ ปี 2025 สถิติการพบ Credential Leak ในหน่วยงานรัฐบาล (GOV) โดยเฉพาะในหน่วยงานด้านบริการภาครัฐที่สำคัญที่พบ Credential Leak สูงสุดถึง 155 เหตุการณ์ รองลงมาคือด้านการเงินและการธนาคาร 14 เหตุการณ์ ด้านการขนส่งและโลจิสติกส์ 8 เหตุการณ์ ด้านความมั่นคงของรัฐ 3 เหตุการณ์ ด้านพลังงานและสาธารณูปโภค 1 เหตุการณ์ และมี 2 หน่วยงานที่ไม่พบ Credential Leak ได้แก่ ด้านเทคโนโลยีสารสนเทศและโทรคมนาคม และด้านสาธารณสุข

ประเภทหน่วยงาน	Event(s)
ด้านบริการภาครัฐที่สำคัญ	155
ด้านการเงินและการธนาคาร	14
ด้านการขนส่งและโลจิสติกส์	8
ด้านความมั่นคงของรัฐ	3
ด้านพลังงานและสาธารณูปโภค	1
ด้านเทคโนโลยีสารสนเทศและโทรคมนาคม	0
ด้านสาธารณสุข	0



แนวทางการป้องกันและรับมือ Credential Leak

1.การบังคับใช้การยืนยันตัวตนหลายปัจจัย (Multi-Factor Authentication - MFA)

- การยืนยันตัวตนหลายปัจจัยช่วยลดความเสี่ยงจากการที่รหัสผ่านรั่วไหล แม้ผู้โจมตีจะได้ข้อมูลไปก็ไม่สามารถเข้าสู่ระบบได้หากไม่มีขั้นตอนการยืนยันเพิ่มเติม

2.การเข้ารหัสข้อมูล (Credential Encryption)

- รหัสผ่านและข้อมูลที่จัดเก็บในฐานข้อมูลควรมีการเข้ารหัสเสมอ เพื่อลดความเสี่ยงจากการเกิดข้อมูลหลุดแล้วถูกนำไปใช้งานได้ทันที
- การใช้การแฮชแบบ Salted Hash ช่วยให้การถอดรหัสทำได้ยากขึ้น แม้ว่าผู้โจมตีจะได้ข้อมูลแฮชไป

3.การตั้งรหัสผ่านที่แข็งแกร่ง (Password Policy)

- บังคับให้ผู้ใช้ตั้งรหัสผ่านที่ซับซ้อน เช่น รหัสผ่านควรประกอบด้วยตัวอักษรใหญ่-เล็ก ตัวเลข และสัญลักษณ์ รวมถึงมีความยาวอย่างน้อย 12 ตัวอักษร
- หลีกเลี่ยงการใช้รหัสผ่านเดิมซ้ำกับหลายๆ บัญชีหรือตั้งรหัสผ่านที่ง่ายเกินไป ซึ่งเป็นสาเหตุที่ทำให้ถูกโจมตีด้วยวิธี Brute Force

4.ระบบการจัดการรหัสผ่าน (Password Management System)

- ควรใช้ระบบจัดการรหัสผ่านที่มีความปลอดภัยและเป็นไปตามมาตรฐาน เช่น Password Vault หรือ Password Manager เพื่อจัดเก็บข้อมูลอย่างปลอดภัยและลดการใช้รหัสผ่านที่ซ้ำกัน

5.การปิดกั้นการเข้าถึงโดยไม่ได้รับอนุญาต (Access Control)

- ใช้การควบคุมสิทธิ์การเข้าถึงในทุกระบบ และกำหนดสิทธิ์ที่เหมาะสมกับหน้าที่ของแต่ละผู้ใช้งาน (Least Privilege) เพื่อจำกัดการเข้าถึงเฉพาะผู้ที่จำเป็นเท่านั้น
- ติดตามและปรับปรุงสิทธิ์ของผู้ใช้อย่างสม่ำเสมอ เพื่อลดความเสี่ยงที่ข้อมูลจะรั่วไหลจากสิทธิ์เกินความจำเป็น

6.การตรวจสอบบันทึกเหตุการณ์และระบบแจ้งเตือน (Central Logging & Monitoring)

- จัดเก็บและตรวจสอบบันทึกเหตุการณ์ (Logs) โดยเฉพาะบันทึกการเข้าสู่ระบบผิดพลาดหรือพยายามเข้าถึงระบบจาก IP ที่ไม่น่าไว้วางใจ
- การตั้งค่าแจ้งเตือนเพื่อแจ้งเตือนผู้ดูแลระบบเมื่อตรวจพบกิจกรรมที่น่าสงสัยจะช่วยให้สามารถตอบสนองได้อย่างรวดเร็ว

7.การฝึกอบรมด้าน Cyber Security Awareness

- สร้างความตระหนักรู้ให้กับพนักงานเพื่อหลีกเลี่ยงพฤติกรรมที่เสี่ยงต่อการรั่วไหลของข้อมูล เช่น หลีกเลี่ยงการบันทึกหรือการคลิกลิงก์แปลกปลอมที่อาจนำไปสู่การถูกขโมยรหัสผ่าน

8.การใช้การตรวจสอบความปลอดภัยอย่างต่อเนื่อง (Continuous Security Testing)

- ทำการทดสอบความปลอดภัย เช่น การทดสอบเจาะระบบ (Penetration Testing) และการประเมินช่องโหว่ (Vulnerability Assessment) เป็นระยะ ๆ เพื่อให้มั่นใจว่าไม่มีช่องโหว่ที่สามารถนำไปสู่การรั่วไหลของข้อมูล

แนวทางการป้องกันและรับมือ Credential Leak

9.การจัดการและตรวจสอบบัญชีผู้ใช้ในฐานข้อมูล

- ลบบัญชีผู้ใช้ที่ไม่ได้ใช้งานและทำการตรวจสอบสิทธิ์การเข้าถึงฐานข้อมูลอย่างสม่ำเสมอ
- กำหนดสิทธิ์การเข้าถึงฐานข้อมูลให้เฉพาะโปรแกรมที่เกี่ยวข้องและอุปกรณ์ที่ได้รับอนุญาตเท่านั้น

10.การตอบสนองเมื่อเกิด Credential Leak

- เปลี่ยนรหัสผ่าน: รีเซ็ตรหัสผ่านที่อาจได้รับผลกระทบทันที และบังคับให้ผู้ใช้ทั้งหมดตั้งรหัสผ่านใหม่
- ตรวจสอบและบันทึกเหตุการณ์: วิเคราะห์บันทึกเหตุการณ์ที่เกี่ยวข้องกับการรั่วไหลของข้อมูลเพื่อระบุวิธีการโจมตี และเก็บหลักฐานเพื่อใช้ในการตรวจสอบหรือรายงานเหตุการณ์
- แจ้งเตือนหน่วยงานที่เกี่ยวข้อง: หากมีข้อมูลส่วนบุคคลรั่วไหล ควรแจ้งให้หน่วยงานที่เกี่ยวข้องทราบตามกฎหมายและข้อบังคับ



References

- Threat Intelligence ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์
- Recorded Future (TI)



ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ (ศปช.)
สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ

Email: thaicert@ncsa.or.th

Website:

<https://www.ncsa.or.th>

<https://www.thaicert.or.th>

120 หมู่ 3 อาคารรัฐประศาสนภักดี (อาคารบี) ชั้น 7 ศูนย์ราชการเฉลิมพระเกียรติ 80 พรรษา
5 ธันวาคม 2560 ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพฯ 10210

